



Seguridad en Redes

Segmentación de redes · VLANs · subnetting · DMZ · routing a fondo → microsegmentación Zero Trust

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 3 · Periodo 2026-2 · Barranquilla, Colombia

El problema: la red plana

En una red plana todos los equipos comparten el **mismo dominio de broadcast**: cada paquete de difusión llega a todos, y todo host alcanza a todo host

Consecuencia de seguridad: un solo equipo comprometido habilita el **movimiento lateral** — del portátil de un invitado al servidor de base de datos sin encontrar fronteras

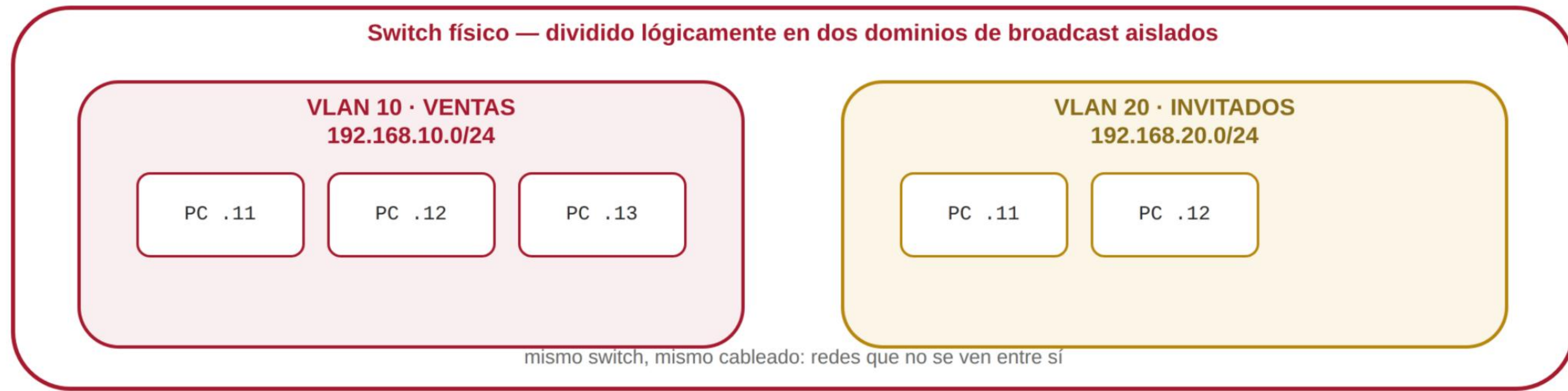
Técnicamente: sin segmentación el firewall solo puede decidir entre "dentro" y "fuera" — nunca entre funciones internas

La segmentación divide la red en zonas con propósito y reglas explícitas entre ellas: **VLANs + subnetting + DMZ** son las herramientas, el router/firewall es quien aplica la política

Principio rector: **una red por función, no una red para todo** — ventas no debe alcanzar contabilidad solo porque comparten el switch.

Esta semana culmina en el laboratorio: diseño real de subredes y segmentación sobre **OPNsense** (Actividad 1 — 10%).

VLANs: dos redes en el mismo cableado



sin router que lo permita expresamente, VLAN 10 y VLAN 20 no se alcanzan aunque compartan el mismo equipo físico

beneficio directo: un host comprometido en invitados no alcanza ventas por movimiento lateral

Estándar **IEEE 802.1Q**: la etiqueta de VLAN viaja dentro de la trama Ethernet · los puertos se asignan a una VLAN o negocian etiquetas por troncal (trunk)

Para comunicar VLANs hace falta **enrutamiento explícito** — ese punto es donde el firewall aplica la política entre zonas

Subnetting: cortar el rango por función



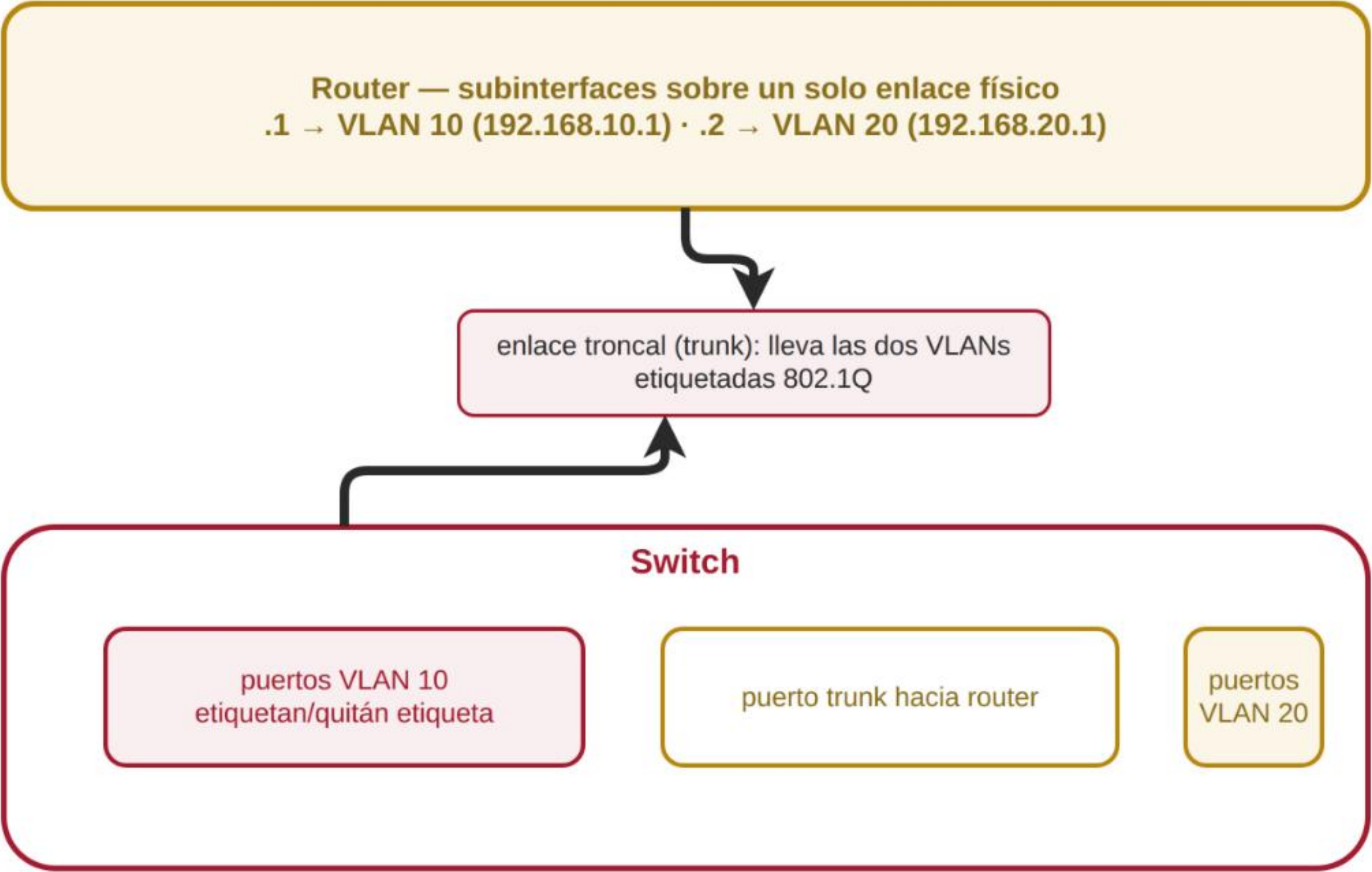
El prefijo crece de /16 a /24: los bits nuevos fijan la subred. Cada red propia = dominio de broadcast controlable y filtrable en el router.

Regla práctica de dimensionamiento: reservar el doble de hosts previstos — reenumerar una red en producción es costoso

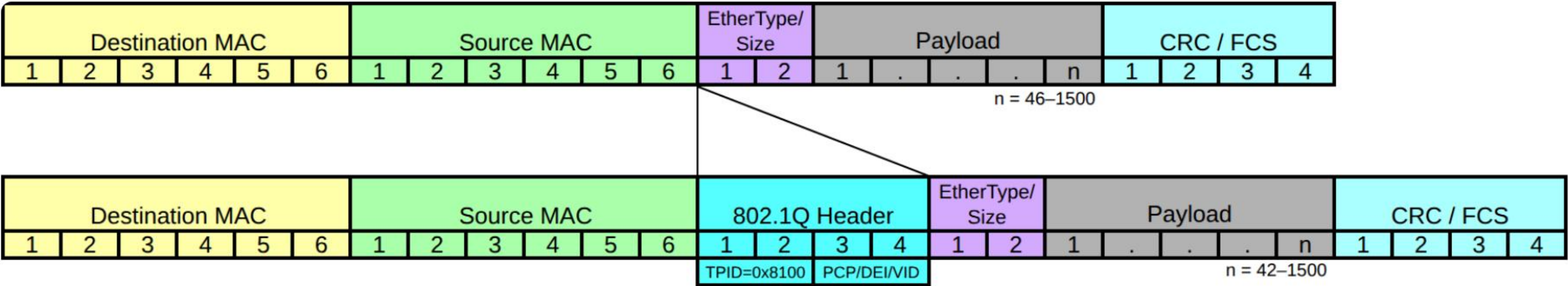
Cálculo: /16 deja 16 bits libres → fijando 8 más (/24) se obtienen 256 subredes de 254 hosts.

En cada subred se reservan la dirección de red (.0) y la de broadcast (.255).

Enrutamiento inter-VLAN: router on a stick

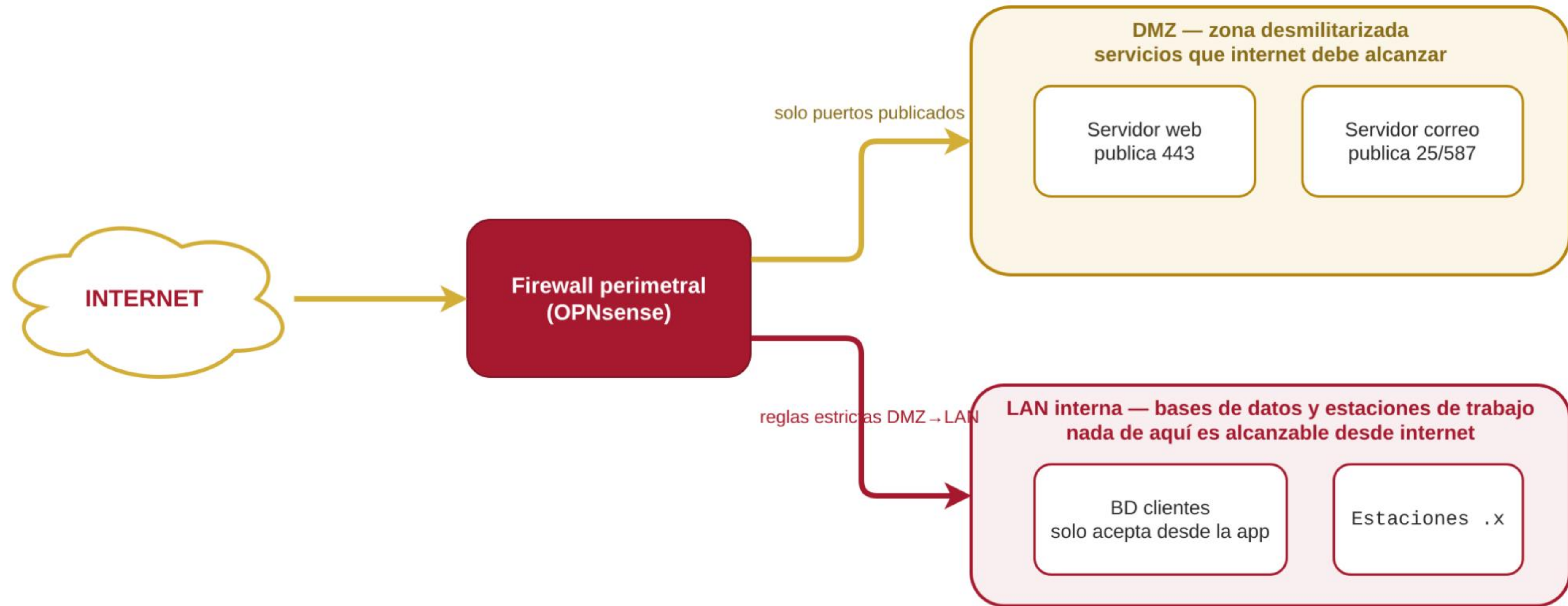


El tráfico entre VLAN 10 y VLAN 20 SUBE al router, es filtrado según la política inter-zona, y BAJA a su destino: punto único de control



Etiqueta 802.1Q: Luca Ghio · Wikimedia Commons · CC BY-SA 4.0

DMZ: zona intermedia para lo publicable



Si la DMZ se compromete, el atacante sigue sin ruta hacia la LAN salvo las reglas expresamente abiertas

La DMZ en una imagen de referencia

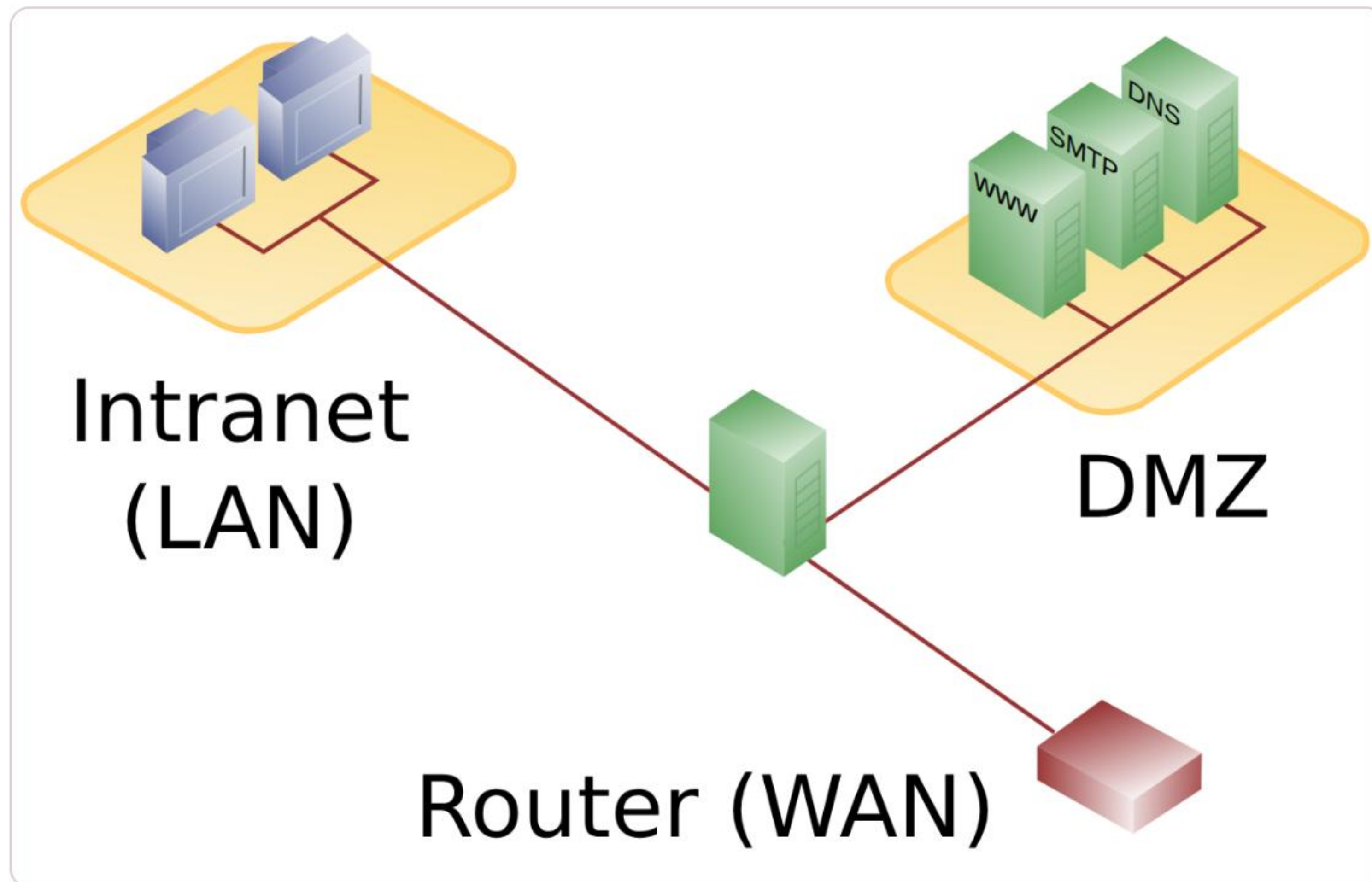


Imagen: Pbroks13 · Wikimedia Commons · dominio público

Es **el mismo diseño de tres zonas** del diagrama propio de esta sesión:
internet — firewall — {DMZ, LAN}

Variante con **dos firewalls** (una DMZ entre ambos) ofrece control doble a mayor costo — misma política, más puntos de decisión

Regla invariable en cualquier variante: **nada de la DMZ inicia conexiones hacia la LAN**; solo responde lo publicado

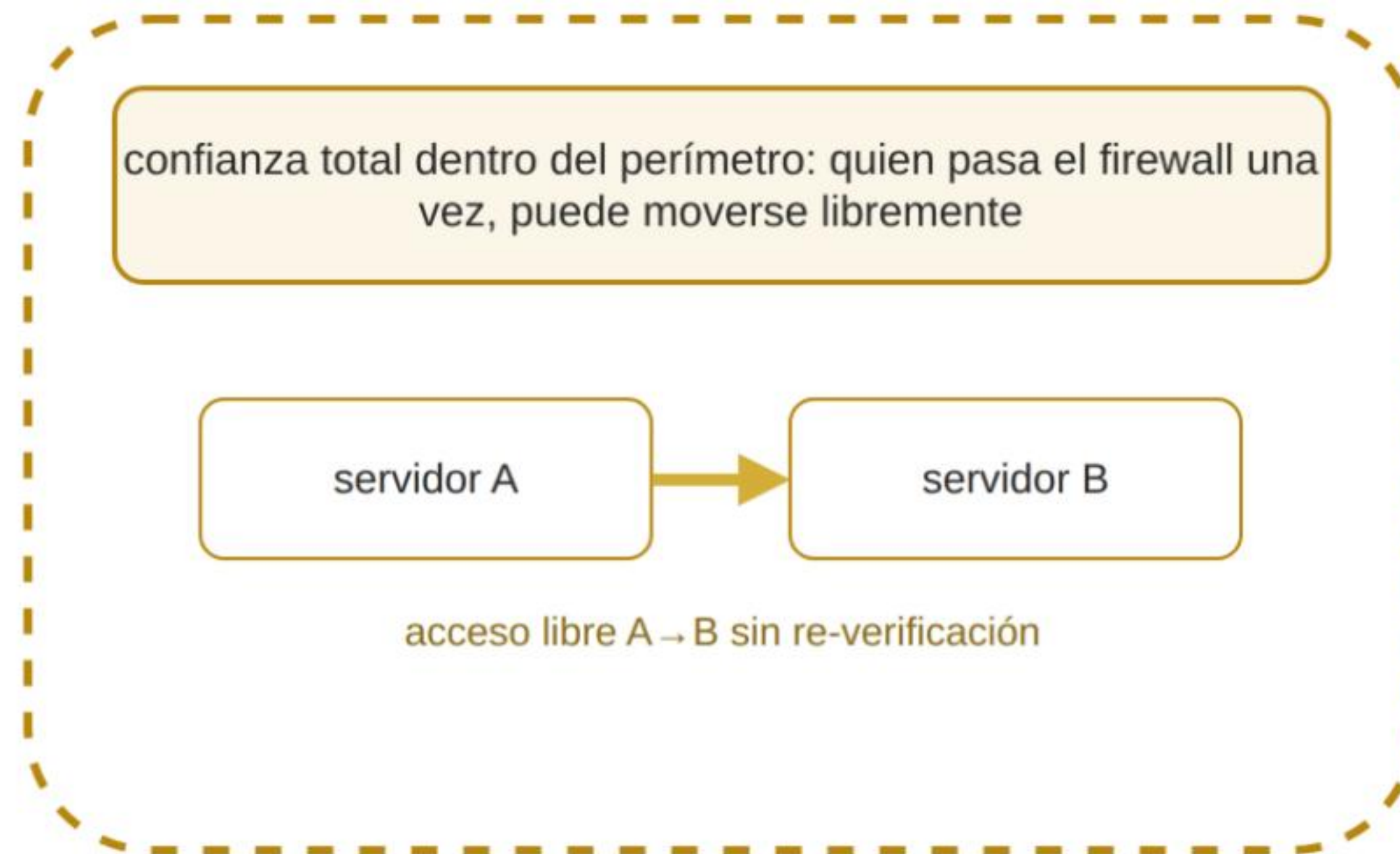
Routing a fondo: estático vs. dinámico

Aspecto	Estático	Dinámico (OSPF · BGP)
Cómo se crean las rutas	A mano, una a una	Los routers se anuncian redes entre sí
Ante caída de enlace	Sin reacción hasta intervención humana	Convergencia automática por ruta alternativa
Predictibilidad	Total — ideal para auditoría de reglas	Menor — depende del protocolo
Escala adecuada	Redes pequeñas o salidas únicas	Múltiples rutas y varias sedes
Relación con seguridad	Rutas fijas = política clara	Requiere filtrar anuncios no autorizados

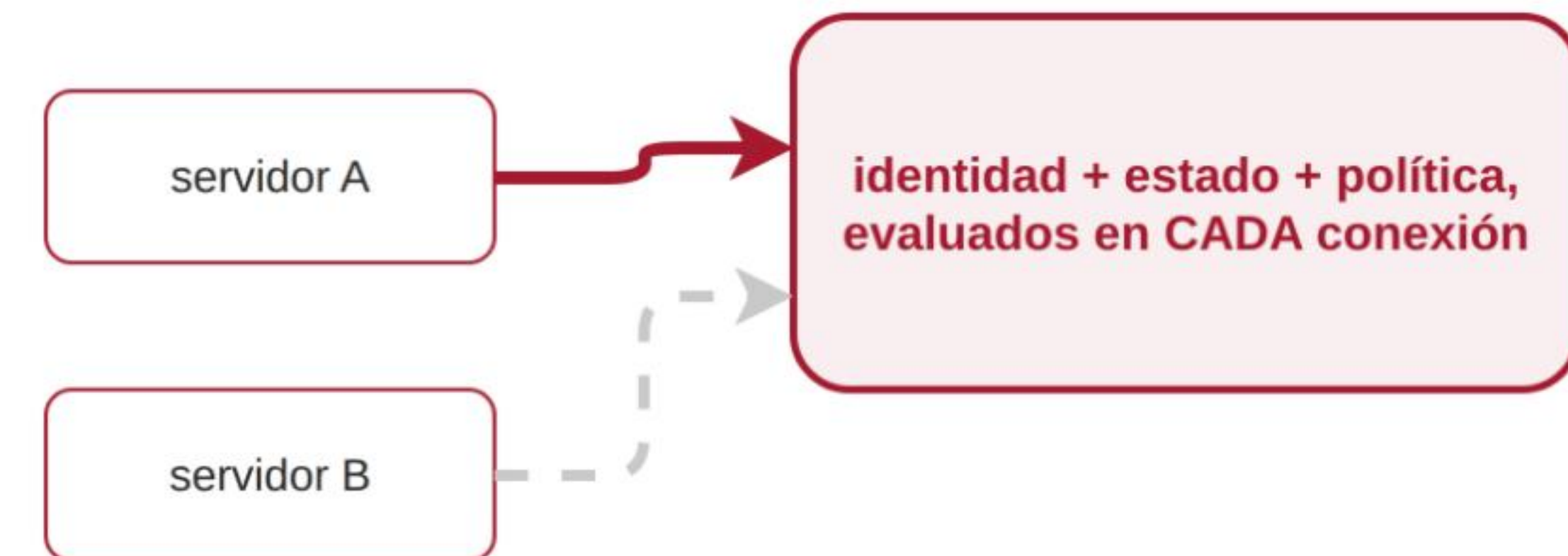
La segmentación multiplica las redes: decidir bien cómo se enrutan entre sí es lo que convierte el dibujo en política efectiva.

Del perímetro a Zero Trust

MODELO PERIMETRAL (castillo y foso)



MODELO ZERO TRUST — nunca confiar, siempre verificar



toda comunicación se autentica y autoriza explícitamente, esté donde esté el recurso

La microsegmentación lleva este principio a la práctica: cada carga de trabajo habla solo con lo que necesita

Microsegmentación: el paso final

Segmentación clásica: zonas por función — la red de ventas, la red de invitados, la DMZ

Microsegmentación: políticas carga a carga — el servidor web habla SOLO con la base de datos en SU puerto; nada más existe para él

Cada workload lleva su propia lista allow/deny: el movimiento lateral queda reducido al mínimo funcional

¿Cómo se implementa? Reglas por host (iptables), security groups por carga en la nube, o políticas en el hipervisor/contenedor — mismo concepto en tres niveles

Es la implementación práctica del principio Zero Trust dentro del datacenter o la nube

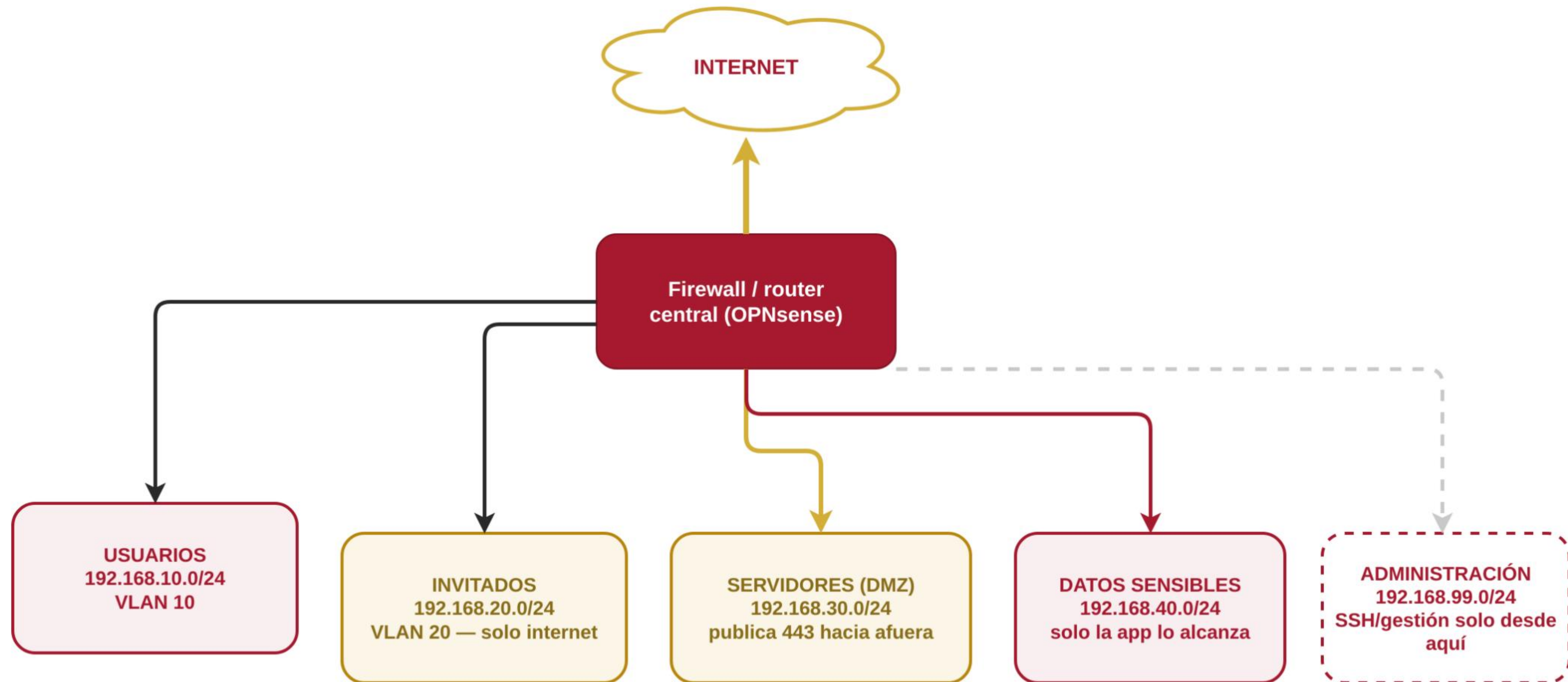
Ejemplo concreto: si el servidor web se compromete, el atacante encuentra exactamente **una salida** — hacia la base de datos, en su puerto. Ni impresoras, ni estaciones, ni otras redes.

Diseñar la segmentación: decisiones clave

Decisión	Criterio recomendado
¿Cuántas zonas?	Una por función con requisitos distintos: usuarios, invitados, servidores públicos, administración, datos sensibles
¿Qué tamaño?	/24 por zona es cómodo (254 hosts) — reservar margen de crecimiento
¿Quién decide qué pasa entre zonas?	El firewall/router central: reglas explícitas zona → zona, denegación por omisión
¿Qué se documenta?	Tabla de zonas con rango, VLAN, gateway y reglas inter-zona — sin documentación la segmentación se degrada

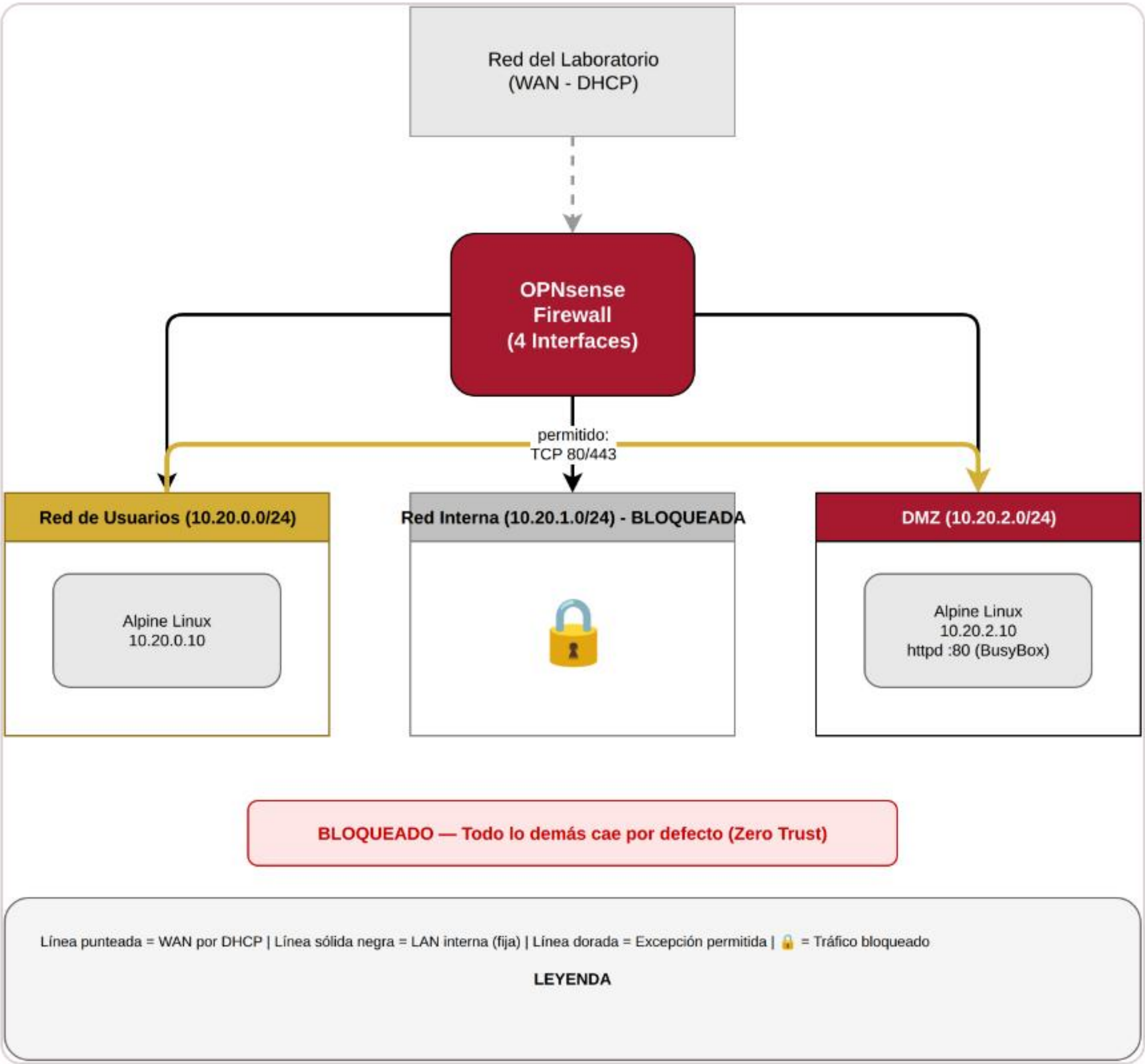
Estas cuatro decisiones son exactamente las que pide documentar la actividad del laboratorio.

Caso práctico: segmentar una sede completa



reglas ejemplo: invitados NO alcanza usuarios ni datos · datos solo recibe TCP 3306 desde servidores · administración no sale a internet

Laboratorio: segmentación real sobre OPNsense



Actividad 1 — 10% · guía completa en `lab-S03-subredes-opnsense.md`: crear las zonas de esta sesión y aplicar las reglas inter-zona diseñadas.